

Narrativa Explicativa – Marco GQM + PRAGMATIC

El RGPD nos obliga a justificar nuestras medidas de seguridad con algo más que frases solemnes sobre la importancia de los datos personales. El enfoque basado en el riesgo exige demostrar que sabemos qué queremos lograr, qué preguntas nos hemos hecho y qué datos utilizamos para responderlas. La metodología GQM aporta este hilo conductor: de los objetivos estratégicos a las métricas concretas. [web:9][web:28]

Sin embargo, no todas las métricas son iguales. Algunas son fuegos artificiales (impresionan en presentaciones, pero poco más), otras son trampas de incentivos (premian el maquillaje de cifras) y unas pocas son realmente útiles para decidir. Los criterios PRAGMATIC nos sirven como detector de humo: permiten evaluar si una métrica es predictiva, relevante, accionable, genuina, significativa, precisa, oportuna, independiente y rentable.

Aplicado al contexto del informe de indicadores RGPD, este doble enfoque tiene varias virtudes: [web:14][web:25][web:22][web:26][web:23][web:27][web:12][web:6][web:11]

1. Alinea los indicadores técnicos (MTTR, porcentajes de cifrado, cobertura de MFA, etc.) con objetivos claramente formulados: menos brechas graves, menos impacto sobre personas, menor exposición a sanciones, mayor resiliencia.
2. Obliga a depurar el catálogo de métricas: no se trata de medir todo, sino de medir lo que realmente cambia decisiones y reduce riesgo.
3. Facilita la trazabilidad regulatoria: cada métrica puede relacionarse con uno o varios artículos del RGPD y con guías específicas (EDPB, ENISA, AEPD), lo que simplifica la conversación con auditores y supervisores.
4. Integra la dimensión económica (ROI) sin caer en el simplismo, permitiendo aproximar la relación entre inversiones de cumplimiento y reducción de costes de incidentes y sanciones.

El resultado esperado es un ecosistema de indicadores en el que cada gráfico del cuadro de mando pueda responder, sin sonrojo, a cuatro preguntas básicas:

- ¿Qué objetivo regulatorio o estratégico estoy persiguiendo?
- ¿Qué pregunta concreta quiero contestar con este indicador?
- ¿Es esta métrica suficientemente buena según PRAGMATIC, o estoy coleccionando números bonitos?
- ¿Qué decisión cambiaría si el valor de la métrica empeora o mejora?

Cuando estas preguntas se responden con naturalidad, la organización deja de usar las métricas como atrezzo y empieza a usarlas como instrumento de gobierno.